Monthly Intelligence Dispatch

September 2017

The Group-IB monthly threat intelligence dispatch is an overview of the strategic changes to the cyber threat landscape, including the most important incidents, leaks and tactical changes in criminal activity. This report includes short term forecasts and warnings, which allow you to take timely measures to protect your critical infrastructure, networks and clients. This report comes in addition to the quarterly and yearly reports that Group-IB prepares, provided alongside our operational and technical data in the Intelligence system and RFI requests from our clients completed by our analyst team.

Executive summary

- Group-IB specialists have found an author of the 0day exploit for the CVE-2017-8759 vulnerability, which was patched by Microsoft in September. This vulnerability is actively used by both financially motivated hackers from the Cobalt group and state-sponsored hackers for the distribution of FinSpy spyware.
- The vulnerability in Apache Struts tracked as CVE-2017-5638 , which was not patched in due time, resulted in the most large-scale and sensitive data leakage in the history of the USA: hackers stole information on 145.5 million people from the credit reporting agency Equifax. The criminals not only got their hands on personal information, but also on bank card details.
- When Shadow Brokers put up the cost of subscription for archives with NSA utilities and exploits, they also increased the amount of transferred data: subscribers will receive not one, but two data dumps per month – and the risks are high that criminals will have more tools for cyberattacks.
- Group-IB has detected a pattern of attacks on cryptocurrency services with the use of phishing resources. One group can earn up to $1.5 million per month.
- A new Trojan for POS terminals called Sisyphus POS, which has recently appeared on hacker forums, may cause an increase in the number of compromised bank cards.
- The emergence of eight vulnerabilities (including 4 zero-day vulnerabilities) in various implementations of the Bluetooth stack for Windows, Linux, Android and iOS led to large-scale discussions on hacker forums, but they do not contain any significant information, since exploits for these vulnerabilities have not yet been released.

Major Events: Cyber Espionage

FinSpy

The FinSpy spyware, which attacked Russian government authorities in August, became the centre of attention in September. **Group-IB Threat Intelligence subscribers received information on this malicious mailout with a detailed technical description and indicators at the end of summer, and on September 12 this incident was publicly reported by FireEye.** FinSpy was developed specially for intelligence agencies and law enforcement by the British subsidiary of Gamma Group – Lench IT Solutions PLC and, according to FireEye, was distributed in Ukraine in early 2017.

The August mailout contained an exploit for the CVE-2017-8759 vulnerability in Microsoft Office. According to Group-IB specialists, this vulnerability has been used in attacks at least since April 2017. We have found a presumable author of the 0day exploit – a criminal called killnum9. Group-IB specialists have found out that this criminal has virtually completed development of a zero-day exploit (remote code execution) for MS Office Excel and he plans to start selling it soon (which Intelligence clients have been informed about in advance). In September, Microsoft released monthly security updates for its products patching 82 vulnerabilities, including one zero-day vulnerability CVE-2017-8759, which was used by hackers to distribute FinSpy.

APT 33

One more spy group described in the September report by FireEye, APT33, was engaged in cyber espionage for Iran. The APT33 group has been active since 2013 – they attacked the US and Saudi airlines, aerospace and power-generating enterprises and military facilities. The hackers registered domains of fake companies to send job ads with malicious attachments. With the use of phishing and DropShot tools, the criminals distributed an improved version of the Shamoon worm called ShapeShift. It has been noticed that **the group has recently started to go beyond the Middle Eastern region and attack organizations in South Korea, Pakistan, Israel and the UK.**

Major Events: Cyber Espionage

Snake

In September, the Snake (Turla or Uroburos) group again became the focus of attention among experts. ESET have found a new backdoor called Gazer used in espionage campaigns against embassies and consulates all over the world, while Kaspersky Lab has reported about an espionage campaign called WhiteBear connected with Turla. In August, Proofpoint reported about attacks on participants and organizers of the G20 summit conducted by the Snake group. Prior to this, the cyberspies from Snake attacked the Swiss defense company RUAG, the US Central Command, research institutes, special services, embassies, and state corporations.

Axiom

The Axiom (APT 17, DeputyDog) Chinese hacker group may have been involved in an attack using a popular PC cleanup tool, Ccleaner, offered by Czech cybersecurity firm Avast. The attackers uploaded infected versions of CCleaner 5.33 and CCleaner Cloud 1.07.3191 to the vendor's website. A backdoor embedded into the utility collected, encrypted and sent information on computer names, installed software and running processes to the C&C server. But the breach was not all – **the hackers tried to attack such large global corporations as Cisco, Samsung, Sony, Intel, Epson, DLink, Oracle (Dyn), Microsoft and Google (Gmail).**

Anonymous

In September, the community's attention was again drawn to activists from Anonymous. This time, Anonymous Greece attacked a Greek government website used for the sale of debtor assets. The activists threatened the Greek government with new attacks. One month before this, the hacktivists from Anonymous attacked the National Health Service of the UK by hacking its appointment system and stealing the data of 1.2 million patients.

Major Events: Data Leakage

Equifax

Massive cyber security incident at Equifax — one of the largest credit reporting agencies in the United States — may have exposed private information belonging to 145.5 million people — nearly half of the U.S. population. Stolen information includes social insurance and driving license numbers, full names and addresses, as well as **compromised bank card numbers for 210,000 people**. The leakage also affected Equifax Canada (over 8,000 people suffered) and Equifax UK, but accurate figures on the damage have not yet been published. After the incident, Richard Smith, Equifax CEO, resigned. The investigation conducted by Mandiant, a FireEye subsidiary, has shown that hackers broke into the Equifax server as early as in May 2017, but remained unnoticed till late July 2017. Smith explained that the leakage was caused by a combination of a human error and a technological error": in March U.S. CERT informed Equifax of the need to patch CVE-2017-5638, a vulnerability in Apache Struts, which eventually caused the breach due to Equifax's failure to install the security updates on time.

Deloitte

A high-profile incident that occurred in September was the leakage of confidential data belonging to clients of Deloitte, one of the world's “big four” accountancy firms. Attackers compromised the company's mail server by hacking its administrator's account, which granted them access to all the resources. Deloitte detected the leakage in March this year, but it is believed that the attackers may have had access to its systems since October or November 2016.

Major Events: Vulnerabilities and Exploits

Shadow Brokers

On September 6, the Shadow Brokers group updated its current prices of subscription for archives with NSA utilities and exploits. **Now, the service's subscribers will receive not one, but two data dumps per month.** Anyone can buy previous dumps by sending a respective amount to the group. Payment can be made only in Zcash. Moreover, according to the publication, the August archive included the UNITEDRAKE tool.

0day

The security researcher Pierre Kim has discovered ten critical zero-day vulnerabilities in D-Link DIR 850L routers. For example, criminals can download a malicious firmware version to the device and compromise it or can obtain the administrator password and gain complete control over the router. The vulnerabilities are so serious that Kim recommends that users stop using this type of routers.

Retefe

Financially motivated hackers have improved the Retefe banking Trojan by adding an exploit from the NSA leakage called EternalBlue. This conclusion has been drawn by researchers at ProofPoint. **Researchers have observed EternalBlue being widely used by cybercriminals – for the WannaCry and NotPetya massive attacks or infection with the TrickBot Trojan**. Retefe, well known for its continuous focus on users in Austria, Sweden, Switzerland and Japan, has recently appeared in the UK. It operates through various proxy servers that are often located in the TOR network.

Major Events: Attacks on Banks

Cobalt

Today's bank robbers are called "financially motivated hackers". Hackers from Cobalt are very well motivated – it is one of the most active criminal groups in the world. All summer, they were attacking banks worldwide, testing new tools and tactics and did not slow down in September – we track their malicious emails almost every week. On September 20, 21 and 25, Cobalt sent emails with a malicious attachment – an RTF file exploiting the CVE-2017-8759 vulnerability patched by Microsoft a week before (the same zero-day vulnerability was used by a group that distributed FinSpy).

Cobalt is actively using new vulnerabilities: in August, they attacked banks in Ukraine, Russia and Kazakhstan with the use of **the vulnerabilities CVE-2017-0262 and CVE-2017-0263 (patched** only **in May) adapted for attacks on financial institutions. Secondly, they used an exploit attributed to a state-backed hacker group called APT28, and thirdly, they applied a new backdoor. Cobalt continues to attack targets all over the world:** on September 5, 2017, a new mailout was detected in Russia, on the next day it was noticed in the USA. A document with an exploit called "New Business Venture.doc" was manually uploaded to VirusTotal from the USA. This exploit is used to deliver the Cobalt backdoor. The document was designed on September 5, 2017, when the group attacked Russian-speaking banks. We suppose that this exploit was also used for attacks on European and US banks. Activities of the Cobalt group in the USA were detected for the first time in June.

#opIkarus

Hackers from Anonymous have conducted about 300 attacks on almost 200 financial organizations all over the world – in Europe and Asia, North America, Australia and Africa. The attacks on the banking sector were caused by antiglobalist ideas. The first attacks of Anonymous hacktivists as part of this operation were tracked in early 2016 and later on these attacks were of a random nature. The goal of Anonymous is not to cause serious damage, but to make a statement or draw attention to a concept. Members of this group with a low level of technical skills usually use open-source software to launch DDoS attacks**. The strength of the group is its capability to recruit large masses for its operations.**

Major Events: Ransomware

Locky	Researchers at Trend Micro have recorded a new spam mailout with ransomware called Locky. The number of malicious emails has risen beyond several million. **The criminals attacked users in Chile, Japan, India and the USA. Russia accounted for 6% of the total number of attacks on average.**
Phantom Squad	A group called Phantom Squad threatened to conduct DDoS attacks on websites of several companies on September 30, if they did not pay 0.2 bitcoins (about $720) each. According to one version, the extortionists may only be imitating Phantom Squad, a hacker group that conducted a series of DDoS attacks on gaming services in the winter of 2015. In the summer of 2017, similar emails were being sent by Armada Collective. The experts found interesting the low ransom request compared to typical demands: for example, when Anonymous blackmailed banks, they demanded 100 bitcoins.
nRansomware	We are now also observing hybrid forms of extortion. A new screen locker called nRansomware demands 10 nude photos from victims instead of money in order to unlock the computer. Once the photos are sent, the victim will receive a code to disable the malware. It appears that the attackers are looking to sell the photos on the deep web to make money.

Major Events

Sisyphus POS

In September, on the underground forum "exploit.in", an advertisement of a new Trojan for POS terminals called "Sisyphus POS" was published. This malware allows bank card details to be compromised. The Trojan and its control panel cost $200. The author claims that the malware has been tested on systems with installed POS terminals running Windows 10, Windows 7 and Windows XP.

Kedi

Security researchers at Sophos have reported about a new remote access Trojan for Windows called Kedi. The malware can hide from antivirus software, contact C&C servers via Gmail and steal users' data. The Trojan is distributed via phishing emails containing a malicious payload disguised as the Citrix tool.

Bluetooth

On September 12, Armis Labs disclosed information on eight vulnerabilities in various implementations of the Bluetooth stack for various operating systems such as Windows, Linux, Android and iOS. **Four of these vulnerabilities were classified as critical – e.g., they can cause the execution of an arbitrary code on a vulnerable device.** Starting from the moment when the information on exploits was published, members of some underground forums have begun to discuss this vulnerability. Group-IB specialists have detected a number of such discussions: on HackForums – initiated by a user called "Mr. WAVES", and on Exploit.IN – initiated by users called "0verLord" and "gcclub". However, these discussions do not contain any significant information, since **exploits for the above mentioned vulnerabilities have not yet been released.**

Major Events

Red Alert

Specialists at SfyLabs (the Netherlands) have reported about a new modification of the Red Alert 2.0 Trojan, which appeared on Russian-speaking hacker forums. The Trojan collects contact lists from infected devices and is able to intercept SMS messages in order to bypass two-factor authentication. It also uses Twitter in order to prevent the loss of bots. If a C&C server specified in the code is not available, the malware obtains a new one from a Twitter account. A similar pattern was previously used only by desktop banking Trojans, while for Android Trojans it is a novelty.

The researchers reported that Red Alert 2.0 did not focus on a specific country, but created HTML overlays for the most famous banks and financial institutions all over the world. This is not entirely the case. **In June, Group-IB informed its customers about the Red Alert Android bot offered for lease ($500 per month), which is designed to steal money from customers of international banks (it is blocked from attacking banks in the CIS!).** The Android bot can intercept and send SMS messages or display fake bank pages. Such pages are designed to steal bank card details and internet bank credentials. In June, the Red Alert owner published ready-made pages of French, Polish and Turkish banks.

ExpensiveWall

Researchers at Check Point reported about a new malicious program for Android called ExpensiveWall. This malware can send SMS messages and withdraw money from accounts in order to pay for access to premium services on fraudulent websites. ExpensiveWall was distributed via Android applications downloaded about 4.2 million times. In total, Google removed about 50 malicious applications from Google Play Store.

Major Events

MoqHao

Researchers at McAfee have found a new banking Trojan for Android called MoqHao that targets South Korean users. The OS is infected through phishing SMS messages (so-called smishing) containing shortened URLs leading to the malware. When MoqHao infects a smartphone, it checks for any popular Korean banking applications installed and displays notifications about available updates for them. When a victim accepts the installation of an update, the malicious application replaces the official one. The MoqHao banking Trojan was first noticed in January 2017 and, in spite of the fact that it was being updated all spring long, experts believe that the malware has not yet been completed, or some functions are still inactive.

Dirty COW

TrendMicro researchers have reported about the emergence of the first Android malware exploiting the Dirty COW vulnerability, which was detected in October 2016. The malware called ZNIU was revealed in more than 1.2 million gaming, pornography and other applications. The malware affected users in 40 countries worldwide – primarily in China, India, the USA, Japan, Canada and Indonesia.

Arrests and Sentences

Gal Vallerius

The US police have arrested a 38-year old French citizen Gal Vallerius (aka OxyMonster) suspected of drug distribution via the underground Dream Market, due to a joint operation of the FBI, Drug Enforcement Agency (DEA), and National Security Agency. Vallerius made a fatal mistake – he left his secret hideout in France to attend the World Beard and Moustache Championships. When he arrived in Atlanta, Georgia, he was detained right at the airport. After examining his laptop, agents confirmed that they had caught OxyMonster. Vallerius was an administrator and moderator of Dream Market, an underground resource, which sold drugs in Europe and the USA. We note that this summer saw the shutdown of the Alphabay and Hansa underground marketplaces and the takedown of RAMP (Russian Anonymous Marketplace).

Gray Liverman

Gray Liverman (aka D3f4ult), a member of Crackas with Attitude (CWA), a hacker group famed for attacks on high-ranking officers of US intelligence agencies, was given a five-year sentence. Crackas with Attitude assumed responsibility for hacking the personal mailboxes of CIA Director, National Intelligence Director, and Deputy FBI Director, and in early 2016 the group leaked information on tens of thousands of US law enforcement officers: 9,000 DHS employees, 20,000 FBI officers, 2,400 government officials, etc. The information was published on CryptoBin, but the intelligence agencies seized CWA servers and traced their members. Earlier, the US court had already sentenced a 23-year old member of the group Andrew Otto Boggs (aka Incursio). As for Liverman, in addition to imprisonment, the court demanded that he indemnify his victims for all their losses by paying $145,000.

Forecasts and Warnings

- Due to a detected vulnerability in the popular D-link router, owners of IoT botnets will be able to greatly increase their capacities, which will most likely be used to conduct DDoS attacks.
- Banking Trojans are starting to acquire self-distribution functionality. This has been detected for Ramnit, Emotet, Trickbot, Qbot, and in September this list was supplemented by Retefe. Such functionality may allow attackers to increase the efficiency of infecting computers used in accounting departments and the number of successful thefts.
- Android banking Trojans are continuing to gain popularity all over the world. The new banking Trojan Moqhao could lead to a rise in the number of incidents in South Korea.
- Shadow Brokers now deliver new tools to their subscribers twice a month. This means that the number of new targeted attacks will continue to grow.
- The data leakage from Equifax may cause a sharp increase in the number of successful attacks on individuals in the USA. The leaked data will be used for social engineering attacks, password recovery mechanisms, improvement of phishing attacks (e.g. when obtained data are incomplete) and other fraudulent schemes.

If you wish to receive more detailed information about a specific incident, threat or criminal group:

Please contact us.

We can conduct investigations to give you the maximum intelligence on the threats targeting your organization.

+1 917 809 47 41
+7 495 984 33 64
intelligence@group-ib.com